衡时

面向国密实现的常量时间性检测与密钥泄漏定位平台

赛道：自由作品赛（软件类，信息安全技术与应用设计）

作品形态：可执行程序 + 检测报告生成器（Windows x64，单文件，无第三方依赖）

文档版本：v1.0　生成时间：2026-11-02

一、作品概述

国密算法本身是安全的，但密码算法的软件实现往往不是常量时间的：执行路径或访存地址一旦依赖密钥，攻击者就能通过缓存时序把密钥还原出来。本作品解决的就是「如何在不修改被测实现、无需插桩、也无需专用采集硬件的前提下，判断一个国密实现是否常量时间，并在判定不安全时给出可复现的证据」这一问题。当前版本面向支持 RDTSCP / CLFLUSH 的 x86 平台，被测源码需编入测试程序。

作品给出两类证据，适用范围不同（这一点在文中处处标明）：

- 统计证据：固定/随机两类输入下的 Welch t 检验，配合 √n 收敛实验区分「真泄漏」与「机器噪声」。覆盖面最广：4 个实测实现 + 3 个干净对照。
- 密码学证据：Flush+Reload 观测缓存行命中，逐轮回归轮密钥，再用密钥扩展的逆推关系还原 128 bit 主密钥。覆盖面较窄：仅在自研实现的行对齐布局上完成，用于证明「泄漏可被利用到什么程度」。

在真实实现上，本作品对两个主流国产密码库（GmSSL、Tongsuo）给出了检测结论，并额外发现二者共用同一份上游实现。

二、问题定义与威胁模型

威胁模型：攻击者与受害者在同一物理机（同进程调用，或共享库映射到同一物理页），能够执行 rdtscp 计时与 clflush，知道自己提交的明文，不知道密钥。目标是判断实现是否常量时间，若否，恢复密钥。该类攻击不需要 root 权限、不需要特殊硬件，在共享云主机、多租户虚拟化场景中现实存在。

作品要回答三个问题：

- 会不会漏（是否常量时间）——要求给出可复现的统计判据，而不是单次观察。
- 漏了多少（危害有多实）——要求在可接受时间内真的把密钥恢复出来。
- 漏在哪（定位与修复）——要求能落到轮次、字节、缓存行粒度，并验证修复有效。

三、国内外研究现状与差异

工作	做了什么	不足
ctgrind (2010)	Valgrind 上标记 secret，检查	只覆盖分支，不管查表；依赖源

	密钥相关分支	码
dudect (2017)	两类别 Welch t 检验	只给「有无」，不给「在哪、怎么修」
DATA / MicroWalk	更细的地址轨迹观测	工程重型，不面向国密工程实践
Binsec/Rel (2021)	二进制级关系式分析	学术工具，接入成本高
国内商用密码测评	硬件侧信道平台（示波器 + 探头）	测芯片不测软件实现，慢、贵

本作品的差异点：面向国密软件实现、不修改被测源码、给出分层证据（统计判定 + 有条件时的密码学实证）、并输出可交付的检测报告（发现编号、严重度、证据、修复建议、复测结论）。

四、系统设计

系统分四层，逐层收敛证据：

层次	做什么	关键点
1 静态画像	表布局、地址对齐、是否只读段	决定单次观测能看到几位密钥
2 统计检测	两类别执行周期 + Welch t	测量前 clflush，两类别交替采样
3 密码学实证	Flush+Reload + 轮密钥回归	乱序探测，避免预取器造成假饱和
4 报告与复测	发现格式化 + 修复后复测	严重度按已证实的可利用程度分级

工程实现要点：rdtscp + lfence 保证计时不被乱序执行污染；绑核 + 高优先级 + 三次取中位降低抖动；两类输入走完全相同的指令路径，避免前置代码差异污染测量（见第六节）。

五、关键技术

1. 统计判据与 √n 收敛

对同一实现采样两类执行周期（固定明文 / 随机明文），裁剪首尾 5% 离群值后计算 Welch t 值：t = (mean_A - mean_B) / sqrt(var_A/n_A + var_B/n_B)，判据 |t| > 4.5。为排除「t 值

是噪声凑出来的」这一质疑，进一步做样本量阶梯实验：真泄漏 |t| 按 √n 增长，噪声不增长。

2. Flush+Reload 与轮密钥回归

每条 trace：flush 四张表全部缓存行 → 用随机明文加密一次 → 依伪随机顺序探测各缓存行重载时间，判定是否被访问。对第 r 轮，表下标字节等于 byte_j(X[r+1]⊕X[r+2]⊕X[r+3]) ⊕ byte_j(rk[r])；对 256 个候选统计「预测行是否在命中集合内」的比例，正确候选接近 100%，错误候选接近随机水平。

3. 主密钥反推

拿到 rk[0..3] 后，利用密钥扩展逆推关系 K[i] = K[i+4] ⊕ T'(K[i+1]⊕K[i+2]⊕K[i+3]⊕CK[i])（i=3,2,1,0），再 MK[i] = K[i] ⊕ FK[i]，即可还原主密钥。

4. 表布局对可观测位数的影响（结论一）

缓存行 64 字节、表项 4 字节，一行装 16 项，因此自然布局下单次观测只能确定表下标的高 4 位；把表项按缓存行对齐后可观测完整 8 位。实验进一步证明：表变小（4 KB → 256 B）并不能消除泄漏——泄漏根源是访存地址由数据决定，不是表的大小（结论二）。

自然布局下的信息边界（负结果）

对 GmSSL / Tongsuo 这类 4 KB T-table 实现，缓存行观测不是零信息，但也达不到密钥恢复。把边界算清：

- 目标轮访问的那一行必然在命中集合中：P(hit | 正确候选) ≈ 1；
- 错误候选对应另一行，被剩余 31 轮碰到的概率：P(hit | 错误候选) = 1 − (15/16)^31 ≈ 86.5%；
- 因此单条 trace 仍有约 13.5 个百分点的区分度，理论上可用大量 trace 恢复「目标表索引落在哪一行」。

真正的边界有三条：同一行内 16 个表项不可区分（每字节约 4 bit）；低半字节歧义在逐轮状态递推中组合爆炸；32 轮访问使命中集合高度饱和（单轮某行未被访问的概率仅约 12.6%），信噪比被进一步压低。结论：自然布局可得到部分信息，当前方法无法稳定完成真实库的完整主密钥恢复。

本作品据此采用两级判定：detection（clean / leak / inconclusive）与 exploit（未验证 / 部分信息恢复 / 完整密钥恢复），两个字段相互独立，避免把「测出了泄漏」误读为「密钥能被恢复」。

六、实验与结果

6.1 实现正确性

两个自研实现（T-table 与常量时间）均通过 GB/T 32907 标准测试向量：密钥与明文均为 0123456789abcdeffedcba9876543210 时，密文为 681edf34d206965e86b3e94f536e4246。

6.2 泄漏检测

实现	中位 t	效应量	判定
T-table（自研）	45.42	5.08%	LEAK
常量时间（自研，修复版）	0.32	0.01%	clean
GmSSL 官方实现	25.05	2.04%	LEAK
Tongsuo-obs 官方实现	65.85	7.12%	LEAK
Tongsuo-pri 官方实现	1.62	0.02%	clean

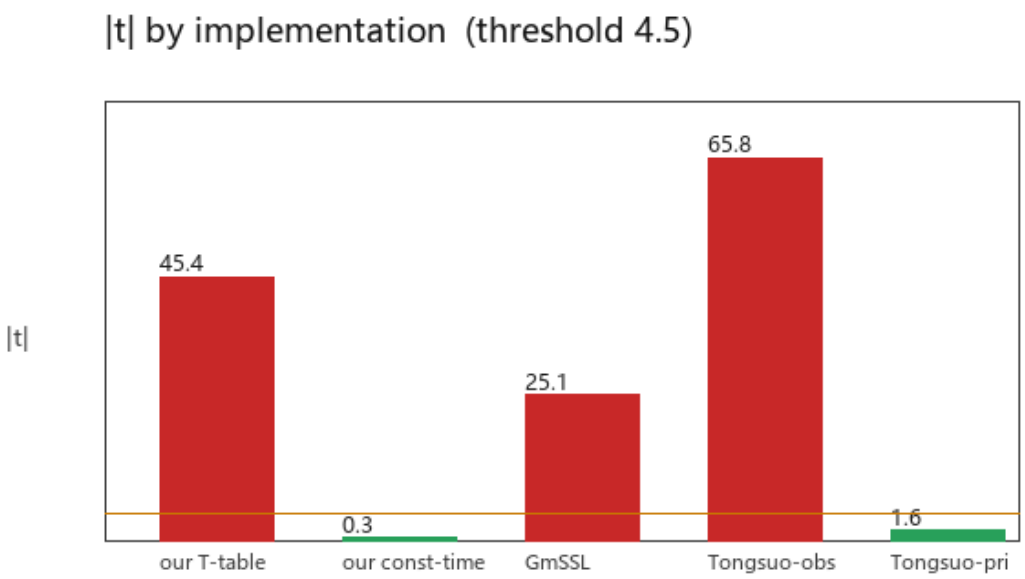


图 1　五种实现的 |t| 对比（阈值 4.5）

6.3 √n 收敛

n/class	|t| T-table	|t| 常量时间
2000	10.71	0.61
5000	17.28	0.70
10000	25.93	0.96
20000	33.49	0.94
40000	49.03	0.55
80000	69.68	0.66

样本量放大 40.0 倍，T-table 的 |t| 放大 6.51 倍（理论 √n 预期 6.32 倍）；常量时间版不随样本量增长。

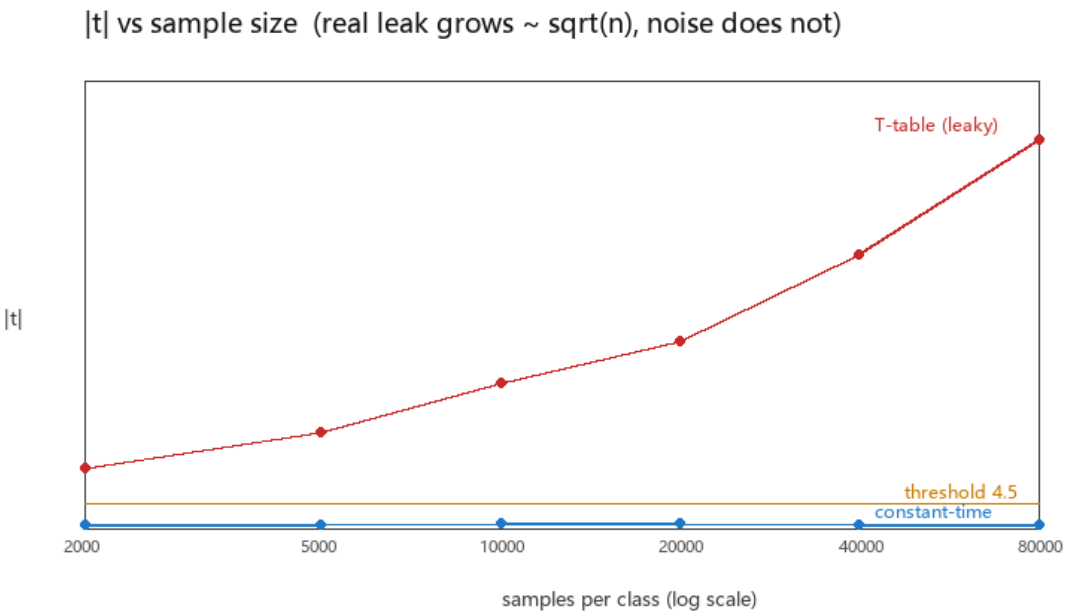


图 2　|t| 随样本量增长：真泄漏 vs 噪声

6.4 密钥恢复

范围说明：密钥恢复仅在自研实现上完成——行对齐布局是为了隔离「表布局」这一变量而构造的受控实验。对 GmSSL / Tongsuo 未实施密钥恢复，对其结论仅限于统计泄漏判定。

行对齐表布局、被攻击实现 32 轮、200 条 trace：

项	值
真实轮密钥	f12186f9 41662b61 5a6ab19a 7ba92077
恢复轮密钥	f12186f9 41662b61 5a6ab19a 7ba92077
反推主密钥	0123456789abcdeffedcba9876543210
真实主密钥	0123456789abcdeffedcba9876543210
是否一致	是

自然布局、4 轮实现作为对照：只能恢复 rk[0] 的高半字节（真实 f1 21 86 f9 → 恢复 f0 20 80 f0），与 6.4 的理论预测一致。



图 3　缓存行命中热图：左为自然布局（饱和），右为行对齐布局

6.5 假阳性评估

实现	真值	越阈值轮次	中位 |t|
our T-table	泄漏	10/10	39.4
GmSSL T-table	泄漏	10/10	18.5
GmSSL small-table	泄漏	10/10	27.0
Tongsuo T-table	泄漏	1/10	1.5
our const-time	干净	0/10	0.7
our const-time rev	干净	0/10	0.6
null baseline	干净	0/10	1.2

本轮实验未观察到假阳性（干净实现的 30 次轮次中 0 次越阈值）。判据为「重复多轮中过半越阈值」，单轮偶发越阈视为噪声。样本量有限，本结论仅描述本轮实验，不外推为总体假阳性率。

严重度按已被实证的可利用程度分级（高 / 待验证 / 信息），不按 t 值或效应量——t 值只反映统计置信度，且随样本量增长，不能作为严重度依据。

6.6 供应链核验

库	版本	commit	许可证	原文 SHA-256（前 16）	核对
GmSSL	v3.2.0	7c9f02904ef3	Apache-2.0	1d7374c8c8fc4ca9	一致
Tongsuo	8.5.0	80cfbe3eb194	Apache-2.0	ada930751c8b9765	一致
BabaSSL	8.5.0	80cfbe3eb194	Apache-2.0	ada930751c8b9765	一致

原文链接（按发行 tag 固定下载，可逐条核对）：

- GmSSL v3.2.0：https://github.com/guanzhi/GmSSL/blob/v3.2.0/src/sm4.c
- Tongsuo 8.5.0：https://github.com/Tongsuo-Project/Tongsuo/blob/8.5.0/crypto/sm4/sm4.c
- BabaSSL 8.5.0：https://github.com/BabaSSL/BabaSSL/blob/8.5.0/crypto/sm4/sm4.c

三个库只对应 2 份独立实现。Tongsuo 与 BabaSSL 的 SM4 源码字节级相同，且两个发行 tag 指向同一 commit：同一份上游实现被两个下游项目共用。这说明「多家实现互相印证」在国产密码库领域不成立，选型必须核验实现血缘。

七、应用前景

- 商用密码应用安全性评估（密评）：为软件密码模块提供常量时间性检测证据，替代纯人工 + 硬件平台的低效流程。
- IoT / 固件供应链：二进制级、无源码依赖，可直接检测第三方提供的库与固件中的密码实现。
- 开发侧回归测试：把检测接入 CI，任何引入数据相关访存的提交都会被拦下。

八、局限与后续工作

- 覆盖范围：目前为 SM4（含两种表布局），尚未覆盖 SM2/SM3；SM2 的标量乘泄漏形态完全不同。
- 运行环境假设：同进程或共享页；跨进程攻击需额外处理。
- 噪声环境：未系统评估多核干扰、虚拟化、超线程对判定的影响。
- 架构覆盖：仅 x86-64，未覆盖 ARM 及国产 CPU 的缓存层次差异。
- 后续：接入更多实现、把泄漏定位精确到源码行/指令偏移、输出对标 GM/T 0028 的合规模板。

九、说明

本作品检测对象均为公开开源实现或其编译配置；密钥恢复实验在作者自有机器、自有实现上完成，不涉及任何第三方系统的未授权访问。作品中引用的上游源码遵循其原始许可证（Apache-2.0 / OpenSSL License）。